תקצירי פתרונות:

שאלה 1

זו שאלה סטנדרטית שוריאציות שלה מופיעות מידי פעם במבחנים. עליכם לצייר מטריצת גישה לפי התנאים הנתונים. במקרה זה נתון שזה מודל BLP אז לפי חוקי המודל ניתן לדעת למי יש הרשאת קריאה ולמי כתיבה. למשל משתמש 1U סודי ולכן יכול לכתוב ל-2F ו-1F ולקרוא מכולם חוץ מ-1F.

לגבי ייצוג בלינוקס/יוניקס – זה בדר"כ ניסוי וטעיה. ניתן להניח שכל אחד שייך לקב' אחת בלבד.

זרימת מידע לא חוקית – מכיון שיש מודל BLP אז בהגדרה אין כזו זרימה.

ערוץ נסתר – בדר"כ יש וגם כאן (למשל ע"י נעילות קבצים).

לגבי סעיף ז' – אופציה אפשרית אחת היא שימוש ב-HIGH WATERMARK.

שאלה 2

כתבו נכון/לא נכון. יש להסביר **<u>בקצרה</u>** את תשובותיכם (2-3 משפטים).

א. פישינג אפשרי רק אם הקורבן לוחץ על קישור זדוני שנשלח לו ע"י התוקף.

לא. יש עוד דרכים (ציינו אחת).

ב. Kerberos חסין להתקפת אופליין עבור תוקף פסיבי המאזין להודעות.

לא. ההודעה הראשונה מהשרת ללקוח חשופה להתקפת אופליין.

ג. חיבור TLS /SSL בינך לבין הבנק יהיה בטוח גם אם הראוטר בביתך נשלט ע"י תוקף.

נכון. הקשר מתבסס על ולידציה של מפתח השרת ולא חשוף להתקפת האיש שבאמצע.

ד. פונקצית HASH קריפטוגרפית טובה לא מייצרת התנגשויות.

מייצרת אבל בסיכוי נמוך.

ה. בהצפנת DES במוד CBC הבלוק האחרון יכול לשמש כ-MAC.

נכון. הבלוק האחרון תלוי בכל הביטים של ההודעה המקורית.

ו. ה-CA שהנפיק תעודה עבור אתר site.com יכול לפענח את כל התעבורה של אתר זה.

לא, הוא לא חשוף למפתח הפרטי.

ז. וירוס מנסה להתפשט לקבצים נוספים במערכת ולהסוות את קיומו.

נכון, כך הגדרנו "וירוס טהור".

ח. בתכנון אנטי וירוס או IDS ,יתרון של זיהוי מבוסס אנומליה על פני זיהוי מבוסס חתימות הוא שבדרך זו ניתן לזהות גם התקפות חדשות.

נכון, וירוס מבוסס חתימות מחפש חתימות של וירוסים ידועים ואילו ע"י חיפוש אנומליה ניתן (במקרים מסויימים לפחות) לזהות פעולות חריגות שייתכן שמקורן בוירוס.

ט. שימוש בקנרית למניעת buffer overflow דורש קימפול (הידור) של הקוד בקומפיילר התומך באופציה זו.

אכן. הקימפול נדרש כדי להוסיף את הקוד השותל את הקנרית ובודק אותה לפני החזרה.

י. בהצפנה ציבורית יש צורך בשליחת המפתח הציבורי בערוץ מאובטח.

לא. זה לא סוד. צריך לוודא שהוא לא משתנה בדרך (למשל ע"י תעודה).

שאלה 3

הסבירו חמישה מתוך ששת המושגים הבאים. יש ללוות בדוגמה כשמתאים.

1. SQL Injection
2. ZERO DAY Vulnerability
3. XSS
4. CFB mode
5. חתימה אלקטרונית
6. תולעת

פה צריך להסביר את המושג בצורה מלאה. זה לא אומר לכתוב דפים שלמים אלא לכלול את כל הדברים הרלוונטיים (ורק אותם). כאמור, יש ללוות בדוגמה כשמתאים.

שאלה 4

א. בודק ש: $M=S^3 \bmod n$.

ב. נבחר ב-S כלשהו. נחשב $M = S^3 \bmod n$ ונשלח את הזוג (M,S).

ג. הוא ישלח את הזוג (8M,2S).

ד. שימוש ב-HASH מבטל את הקשר הישיר בין ההודעה לחתימה.

שאלה 5

א. עשינו דברים כאלה בשיעור ויש במצגות ובספר.

לגבי האם עדיף פסיבי או אקטיבי – זה לא צריך להיות תשובת בי"ס. דיון ביתרונות ובחסרונות.

ב. למשל – קוד שבו ניתן לדרוס משתנה לוקלי. כל ההגנות מתמודדות עם דריסת ערך החזרה ואילו כאן לא דרסנו אותו.

(תזכורת: כל התשובות הינן תקצירים. יש לפרט בכל אחד מההסברים)

ב ה צ ל ח ה !